

# NIST CSF 2.0 – Functions & Categories

## 6 Core Functions.

### 1. GOVERN (GV)

| <u>Category</u> | <u>What It Means</u>                                                           |
|-----------------|--------------------------------------------------------------------------------|
| GV.OC           | Organizational Context – Understanding the business mission and constraints    |
| GV.RM           | Risk Management Strategy - How the organisation identifies and priorities risk |
| GV.RR           | Roles, Responsibilities and Authorities - Who is accountable for security?     |
| GV.PO           | Policy - Document rules and standards (e.g. Access Control policy)             |
| GV.SC           | Supply Chain Risk Management - Managing third party risks                      |

### 2. IDENTIFY (ID)

| <u>Category</u> | <u>What It Means</u>                                                         |
|-----------------|------------------------------------------------------------------------------|
| ID.AM           | Asset Management – Knowing your hardware, software, and data                 |
| ID.RA           | Risk Assessment - Identify threats and vulnerabilities (e.g. Risk Register ) |
| ID.IM           | Improvement - Lessons learned from incidents and audits                      |

### 3. PROTECT (PR)

| <u>Category</u> | <u>What It Means</u>                                           |
|-----------------|----------------------------------------------------------------|
| PR.AA           | Identity & Access Management - MFA. Passwords and off boarding |
| PR.AT           | Awareness & Training - Security                                |
| PR.DS           | Data Security - Encryption and data classification             |
| PR.PS           | Platform Security - Hardening servers and endpoints            |
| PR.MA           | Maintenance - Patching and updating systems                    |

## 4. DETECT (DE)

| <u>Category</u> | <u>What It Means</u>                                            |
|-----------------|-----------------------------------------------------------------|
| DE.AE           | Adverse Events Analysis - detecting suspicious activity         |
| DE.CM           | Continuous Monitoring - Logs, alerts, and areal time monitoring |

## 5. RESPOND (RS)

| <u>Category</u> | <u>What It Means</u>                                        |
|-----------------|-------------------------------------------------------------|
| RS.MA           | Incident Management - Activating the incident response plan |
| RS.AN           | Analysis - Investigating the root cause                     |
| RS.CO           | Communication - Telling the right people (CEO, Legal. PR)   |
| RS.MI           | Mitigation - Stopping the spread                            |
| RS.IM           | Improvement - Learning from the incident                    |

## 6. RECOVER (RC)

| <u>Category</u> | <u>What It Means</u>                                        |
|-----------------|-------------------------------------------------------------|
| RC.RP           | Recovery Plan - Executing backups and restoring on recovery |
| RC.CO           | Communication - Updating stakeholders on recovery progress  |